

Day 22 Report – Social Engineering Tools & Session Hijacking

Date: 10 July 2025

Module: Social Engineering Simulation + Session Hijacking Theory

Mode: Practical + Theoretical

Main Focus

Day 23 focused on the **practical application of social engineering techniques** using various tools, followed by a comprehensive **theoretical session on Session Hijacking**—a network-based attack technique that compromises web sessions.

Social Engineering Practical (Part 1)

Tools Used

- **SET (Social Engineering Toolkit):**
Used to clone websites and harvest credentials
- **USB Rubber Ducky / Manual Payload:**
Simulated attack to auto-create admin users
- **Fake Tech Support Simulation:**
Trained on psychological techniques used in scam calls

Practical Tasks

- Created **fake Facebook login page** using SET:

```
mathematica
Copy code
setoolkit → Social Engineering Attacks → Website Attack Vectors →
Credential Harvester
```

- Simulated a **USB drop attack**:
Auto-launched a script to create hidden user accounts
- Demonstrated **voice-based social engineering** scenarios

Key Learnings

- SET enables fast setup of phishing sites
 - Social engineering is **highly effective** due to human error
 - Defense includes **user awareness, browser protection, email filtering**
-

What is Session Hijacking?

- Session hijacking refers to taking control over an **active web session** between a client and server.
 - An attacker can **impersonate a victim user** by stealing or predicting their session ID (token).
-

Where it Fits in OSI Model?

OSI Layer	Session Hijacking Form
Layer 7 (Application)	Cookie/session ID theft (e.g., HTTP hijacking)
Layer 4 (Transport)	TCP session hijacking
Layer 3 (Network)	IP spoofing and MITM attacks

Spoofing vs Hijacking

Spoofing	Hijacking
Faking identity	Taking over valid session
Focuses on deception	Focuses on takeover
Example: IP/MAC spoofing	Example: Session token theft

How Sessions Get Compromised

1. **Sniffing Unencrypted Traffic (HTTP):**
 - Use tools like Wireshark or Burp Suite
 - Intercept session ID in HTTP requests
 2. **XSS Attacks:**
 - Steal session ID stored in cookies using JavaScript payload
 3. **Man-in-the-Middle (MITM):**
 - Using ARP spoofing + packet sniffing to monitor and alter sessions
 4. **Session Fixation:**
 - Forcing user to log in with attacker-known session ID
-

Predicting Session Tokens

Attackers may guess weak or sequential tokens, especially when:

- Session IDs are generated using **predictable algorithms**
- No proper entropy or randomness in ID creation

Example:

If session ID = `user123456`, attacker may try `user123457`, `user123458`, etc.

Tools that help in guessing tokens:

- **Burp Suite Intruder**
 - **Hydra** with session replay
 - **Custom Python scripts**
-

Key Takeaways

- Session hijacking is dangerous, especially over **HTTP or open Wi-Fi**
- It affects **confidentiality and authentication**
- Best defenses include:
 - HTTPS everywhere (SSL/TLS)
 - Secure and HttpOnly flags in cookies
 - Random, long, and unpredictable session IDs
 - Automatic session expiration and logout timers